



Eidgenössische Technische Hochschule Zürich
Swiss Federal Institute of Technology Zurich

Informationssicherheit

ETH Zürich
Johannes Hadodo
CISO, Head Cyber and Information Security
OCT G 12
Binzmühlestrasse 130
CH-8092 Zürich

Telefon +41 44 633 65 61
johannes.hadodo@ethz.ch
www.its.ethz.ch

INTERN

Zürich, 24. Juli 2025

Informationssicherheit und künstliche Intelligenz (KI) Leitfaden für Nutzende von KI-Tools an der ETH Zürich

Künstliche Intelligenz (KI), insbesondere generative KI, verändert stark die Art und Weise, wie wir arbeiten und kommunizieren. Dieser Leitfaden beschreibt sicherheitsrelevante Aspekte bei der Nutzung von KI-Technologien.

Die Nutzung von KI-Systemen wie ChatGPT oder Copilot – auch jene, die von der ETH zur Verfügung gestellt werden – birgt Chancen aber auch Risiken. Einerseits kann beispielsweise die Produktivität erhöht und die Lösungsfindung bei Problemstellungen vereinfacht werden, andererseits besteht jedoch auch das Risiko von Datenlecks, Verletzungen der Privatsphäre oder manipulierter KI-Systeme. Das Ziel im Umgang mit KI soll deshalb sein, die Chancen zu nutzen aber die Risiken zu minimieren.

Es liegt in der Verantwortung der Nutzenden, KI-Dienste bestimmungs- und verantwortungsvoll zu nutzen. Unter der bestimmungsgemässen Nutzung verstehen wir einen mit dem geltenden Recht und den ETH-Weisungen konformen Einsatz der KI. Die verantwortungsvolle Nutzung schliesst den bestimmungsgemässen Einsatz mit ein und geht darüber hinaus: Zusätzlich setzen wir Massnahmen um, welche eine besondere Umsicht und Vorsicht im Umgang mit Informationen signalisieren. Die verantwortungsvolle Nutzung ist – im Vergleich zur bestimmungsgemässen Nutzung – nicht vorgeschrieben; aber: Sie ist sehr erwünscht. Wir zeigen, dass wir unsere sowie die Daten unserer Lieferanten und Forschungspartner als höchstes Gut erachten und mit diesen Daten vorbildlich umgehen, was über die Berücksichtigung der notwendigen Sorgfaltspflicht hinausgeht.

Bestimmungsgemässe Nutzung von KI-Systemen (regulatorische Konformität)

Künstliche Intelligenz bezieht sich auf die Fähigkeit von Maschinen, Aufgaben auszuführen, die normalerweise menschliche Intelligenz erfordern, wie z.B. Lernen, Problemlösung und Entscheidungsfindung.

Generative KI ist in der Lage, neue Inhalte wie Texte, Bilder oder Musik zu erstellen. Diese Systeme nutzen maschinelles Lernen und neuronale Netzwerke und werden mit grossen Datensätzen trainiert. Sie können auch für bestimmte Aufgaben wie Übersetzungen spezialisiert werden.

Regulatorisch konformer Schutz von Daten, Persönlichkeits- und Rechte Dritter

Gemäss der Weisung Informationssicherheit an der ETH Zürich¹ ist der Schutz der Vertraulichkeit, Integrität und Verfügbarkeit von Informationen von höchster Wichtigkeit. Die unbefugte Offenlegung vertraulicher Informationen, zum Beispiel, könnte unserer Institution, Kunden oder Kooperationspartnern irreparablen Schaden zufügen.

Wir gehen deshalb bestimmungsgemäss mit internen und vertraulichen Informationen, Geschäftsgeheimnissen und geistigen Eigentumsrechten um – unabhängig davon, ob es sich um unsere eigenen oder um Informationen privatwirtschaftlicher Unternehmen und Einzelpersonen handelt oder um lizenzierte Inhalte, wie Publikationen, die von der ETH-Bibliothek zur Verfügung gestellt werden.

Der bestimmungsgemässe Umgang gilt sowohl für die Art der Nutzung (entweder man befragt ein KI-System oder man trainiert ein KI-System) als auch für die Art der verwendeten Informationen – seien es Sach- oder Personendaten.

Zum Beispiel dürfen bei einer ausgeschriebenen Stelle ohne menschliche Interaktion keine automatisierten, personenbezogenen Entscheide getroffen werden. Zudem gilt: Sollte es zu einer Datenschutzverletzung kommen, bei welcher Personendaten verloren gehen, mutwillig zerstört, unbefugt gelöscht, verändert oder zugänglich gemacht werden, muss dies dem Datenschutzberatern der ETH Zürich gemeldet werden. Weitere Informationen finden Sie hier:

<https://ethz.ch/staffnet/de/service/rechtliches/datenschutz.html>

KI-Systeme sind in der Regel als externe Cloud- bzw. externe IT-Dienste einzustufen (solche Dienste werden der ETH von einer Drittpartei angeboten). Eine Liste freigegebener externer Cloud-Dienste für die ETH Zürich ist hier einsehbar und wird in Zukunft auch KI-Systeme beinhalten:

<https://ethz.ch/staffnet/de/service/informationssicherheit/nutzung-externer-cloud-dienste/freigabeliste-fuer-externe-cloud-dienste.html>

¹ RSETHZ 203.25, <https://rechtssammlung.sp.ethz.ch/dokumente/203.25.pdf>

Gemäss dem ETH-Klassifikationssystem der ETH Zürich² dürfen maximal «vertrauliche» Informationen in externen Cloud-Diensten bearbeitet werden – sofern diese Dienste hierfür freigegeben sind. «Streng vertrauliche» Informationen dürfen weder in einem externen Cloud-Dienst ausgelagert noch bearbeitet werden.

Die gelegentliche angemessene Nutzung externer Cloud- bzw. IT-Dienste zur Unterstützung im Tagesgeschäft (z.B. Suchmaschinen, Online-Übersetzungsservices, Chatbots mit künstlicher Intelligenz, ChatGPT), die nicht von der ETH Zürich freigegeben sind, liegt in der Verantwortung der Benutzenden. Besonders schützenswerte Personendaten nach Datenschutzgesetz³ (DSG) Art. 5 Bst. c sowie anderweitig vertrauliche oder streng vertrauliche (Sach- oder Personen-) Daten dürfen mit solchen Diensten nicht bearbeitet werden.⁴

Darüber hinaus widersprechen einer bestimmungsgemässen Nutzung der KI-Systeme insbesondere⁵:

- diskriminierende, belästigende, betrügerische, verleumderische oder anderweitig nach dem Recht verbotene Handlungen;
- das Ausschalten, Umgehen oder Entfernung von Sicherheits- oder Auditing-Systemen der ETH oder einer anderen Organisation ohne vorherige Genehmigung oder
- die Verletzung der Rechte Dritter inklusive Urheber-, Persönlichkeits- oder Lizenzrechte (z.B. bei nicht bestimmungsgemässer Nutzung lizensierter Daten).

² RSETHZ 203.28, <https://rechtssammlung.sp.ethz.ch/Dokumente/203.28.pdf>

³ Datenschutzgesetz (DSG), <https://www.fedlex.admin.ch/eli/cc/2022/491/de>

⁴ RSETHZ 203.21, <https://rechtssammlung.sp.ethz.ch/Dokumente/203.21.pdf>

⁵ RSETHZ 203.21, <https://rechtssammlung.sp.ethz.ch/Dokumente/203.21.pdf>, Art. 11, Art. 14, Art. 3

Verantwortungsvolle Nutzung von KI (Umsicht und Sorgfalt)

Mitarbeitende dürfen KI im Arbeitsalltag nutzen, z.B. für das Erstellen interner Arbeits-E-Mails oder für Präsentationen. Sie befolgen dabei die Vorgaben im Abschnitt «Bestimmungsgemässe Nutzung von KI-Systemen» auf Seite 2 und erwägen zusätzlich die untenstehenden Massnahmen für eine verantwortungsvolle Nutzung.

Erweiterter Schutz für Personendaten und der Rechte Dritter

Im Gegensatz zur bestimmungsgemässen Nutzung, verstehen wir unter *verantwortungsvoller* Nutzung die Verwendung von KI ohne ...

- ... personenbezogene Daten. Personenbezogene Daten sind sämtliche Informationen, die sich auf eine identifizierte oder identifizierbare natürliche Person (betroffene Person) beziehen; eine identifizierbare natürliche Person ist eine Person, die direkt oder indirekt bestimmt werden kann, insbesondere durch Zuordnung zu einer Kennung wie einem Namen, einer Identifikationsnummer, Standortdaten, einer Online-Kennung oder zu einem oder mehreren besonderen Merkmalen, die Ausdruck der physischen, physiologischen, genetischen, psychischen, wirtschaftlichen, kulturellen oder sozialen Identität dieser natürlichen Person sind;
- ... besonders schützenswerte Personendaten. Besonders schützenswerte personenbezogene Daten sind Informationen über Gesundheit, ethnische Herkunft, politische Meinungen, religiöse oder philosophische Überzeugungen, Gewerkschaftszugehörigkeit, genetische Daten, biometrische Daten (zum Zweck der Identifizierung) sowie Daten zur Sexualität oder zur sexuellen Orientierung;
- ... Informationen, die die ETH oder Dritte identifizieren.

Leitlinien für den Einsatz von KI in Lehre und Forschung⁶

Als führende Forschungseinrichtung will die ETH bei der Entwicklung und dem Einsatz von KI-Technologien besonders verantwortungsvoll vorgehen. Dies umfasst die Berücksichtigung ethischer Fragen und die Integration von KI-Ethik in Lehrpläne. Die ETH Zürich hat Leitlinien für den Einsatz von KI in der Lehre entwickelt, die folgende Aspekte berücksichtigt:

1. Förderung des kritischen Denkens: Studierende werden ermutigt, die Möglichkeiten und Grenzen von KI kritisch zu hinterfragen;
2. Ethische Nutzung: Die ETH legt Wert darauf, dass KI-Tools in der Lehre ethisch und verantwortungsvoll eingesetzt werden;
3. Anpassung der Lehrmethoden: KI wird genutzt, um personalisiertes Lernen zu ermöglichen und die Interaktion zwischen Lehrenden und Studierenden zu verbessern;
4. Vorbereitung auf die Arbeitswelt: Studierende werden auf eine Zukunft vorbereitet, in der KI eine zentrale Rolle spielen wird.

⁶ KI im Bereich Lehre und Lernen, <https://ethz.ch/de/die-eth-zuerich/lehre/ai-in-education.html>

Berücksichtigung gesellschaftlicher Auswirkungen von KI

Die ETH nimmt eine wichtige Rolle bei der Untersuchung und Bewertung gesellschaftlicher Auswirkungen von KI-Technologien ein. Dies spiegelt sich auch in der KI-Strategie für die Lehre wider und soll Studierende befähigen, die Auswirkungen von KI auf verschiedene Bereiche der Gesellschaft zu verstehen und gegebenenfalls mitzugestalten.

Folgende Dos and Don'ts unterstützen die bestimmungsgemässe und verantwortungsvolle Nutzung.

Praktische Tipps: Dos und Don'ts

Nutzen Sie KI in der Praxis, um zu lernen, wie Sie die Technologie am besten für Ihre Arbeit einsetzen können. Experimentieren Sie mit verschiedenen KI-Tools und nutzen Sie KI, um Routineaufgaben zu automatisieren. Hier sind einige Dinge, die Sie tun und vermeiden sollten:

Dos:

- Schreiben Sie aussagekräftige Prompts
Wenn Sie Prompts für konversationelle KI wie ChatGPT erstellen, folgen Sie diesen Empfehlungen, um bestmögliche Resultate sowie Datensicherheit sicherzustellen:
 1. Drücken Sie sich klar aus, geben Sie dem Prompt Kontext; verwenden Sie Schlagworte; achten Sie auf korrekte Rechtschreibung; definieren Sie die Rolle der KI und den gewünschten Output;
 2. Verwenden Sie keine persönlichen, vertraulichen oder proprietäre Informationen⁷;
 3. Verwenden Sie respektvolle Sprache und Ausdruck;
 4. Fördern Sie Diversität und Inklusion;
 5. Evaluieren und verfeinern Sie Ihre Prompts regelmässig;
 6. Geben Sie nur notwendige Informationen an KI-Systeme weiter (Datenminimierung);
 7. Nutzen Sie Funktionen zum Löschen Ihrer Interaktionshistorie mit KI-Assistenten und löschen Sie regelmässig Cookies (regelmässige Datenlöschung);
 8. Suchen Sie nach KI-Diensten mit lokaler Verarbeitung oder starken Datenschutzgarantien;
 9. Deaktivieren Sie Datensammlungen für «Produktverbesserungen» wenn möglich;
 10. Verringern Sie ein Halluzinieren bereits bei der Eingabe des Prompts⁸.

Weitere Information und Beispiele zum Prompting:

<https://ethz.sharepoint.com/sites/ArtificialIntelligence>

⁷ Beispiele: Personenidentifizierende Angaben, ETH-Projektunterlagen, nicht öffentliche Konzeptpapiere oder Aspekte softwarebezogener Intellectual Property, Geschäftsgeheimnisse der ETH sowie Dritter, urheberrechtsgeschützte Daten

⁸ Beispiel: «Die folgende Frage sollte nur beantwortet werden, wenn verlässliche Informationen vorliegen. Falls keine eindeutige oder belastbare Antwort gegeben werden kann, ist explizit anzugeben, dass keine ausreichenden Informationen vorliegen. Vermutungen oder Annahmen sind zu vermeiden». Mögliche Ergänzung: «Es ist ausschliesslich auf bekannte, überprüfbare Quellen zu verweisen oder zu erklären, warum keine Antwort möglich ist».

- Überprüfen Sie die Ergebnisse der KI kritisch
Lesen und prüfen Sie den Output von generativer KI, um die Qualität, Genauigkeit und ethischen Implikationen der generierten Inhalte zu bewerten, bevor Sie diesen weiterverwenden. Mitarbeitende müssen alle von KI produzierten Resultate auf Genauigkeit und Faktentreue überprüfen, bevor sie diese für offizielle Zwecke verwenden, einschliesslich des Versands von E-Mails, Präsentationen, Dokumenten oder anderen Materialien.
- Schalten Sie die Verlaufsfunktion aus (falls möglich)
Bestimmte KI-Lösungen bieten Optionen zur Einschränkung der Speicherung und Nutzung der bereitgestellten Daten. Nutzen Sie diese, um zu verhindern, dass Ihre Daten unkontrolliert im Netz weiterverwendet werden.
- Berücksichtigen Sie unbedingt das Urheberrecht bei KI-generierten Inhalten
Die ETH hat Leitlinien für die Nutzung und Verbreitung von KI-generierten Inhalten entwickelt, insbesondere im Kontext von Lehre und Lernen. An der ETH wird akademische Integrität als Haltung verstanden: KI-Nutzende übernehmen Verantwortung, kennzeichnen den Einsatz von KI und gehen fair mit Datenschutz und Urheberrecht um.

Weitere Informationen sind hier: <https://ethz.ch/de/die-eth-zuerich/lehre/ai-in-education.html>

Dont's:

- Teilen Sie keine vertraulichen Informationen mit KI-Systemen
Neben dem Nutzen künstlicher Intelligenz, sollten Sie sich ebenfalls den Risiken bewusst sein. Die falsche Nutzung von KI kann mehrere Gefahren für Sie und die ETH darstellen:
 1. Reputationsschäden, z.B. aufgrund der Verletzung geistigen Eigentums, aufgrund fehlenden Verständnisses für den Forschungsschutz, aufgrund von Verstössen gegen das Urheberrecht, gegen Lizenzrechte und Datenschutz;
 2. Ethische Bedenken, z.B. aufgrund mangelnder Wissenschaftsethik und akademischer Integrität oder aufgrund möglicher Plagiate und/oder
 3. Finanzielle Verluste.
- Teilen Sie keine Personendaten
Eine Beschreibung personenbezogener Daten sowie besonders schützenswerten Personendaten finden Sie unter dem Titel «Verantwortungsvolle Nutzung von KI» auf Seite 4.

- Verlassen Sie sich nicht blind auf KI-Ergebnisse
Seien Sie bei der Überprüfung KI-generierter Texte gründlich. Wenn Sie die KI gebeten haben, Inhalte zu erstellen, achten Sie auf Folgendes:
 1. Mangelnde Kohärenz: Ein fehlender logischer Aufbau KI-generierter Texte kann zu missverständlichen oder unklaren Passagen führen;
 2. Semantische Fehler: KI-Modelle können gelegentlich den Kontext falsch interpretieren, was zu Fehlern, Ungenauigkeiten oder unplausiblen Aussagen führt;
 3. Wiederholungen: KI-generierte Inhalte können wiederholte Muster oder redundante Informationen aufweisen, die die Qualität und Einzigartigkeit des Textes beeinträchtigen und/oder
 4. Halluzinationen: KI-generierte Halluzinationen können sehr plausibel klingen und werden zum Teil sogar mit vermeintlichen bibliographischen Quellen belegt, die jedoch nicht existieren;
- Berücksichtigen Sie die ethischen Richtlinien, Datenschutzbestimmungen und andere anwendbare Gesetzgebung

Risiken und Herausforderungen

Datenlecks und Verletzungen der Privatsphäre

KI-Systeme verarbeiten oft grosse Mengen an Daten, was sie zu attraktiven Zielen für Cyberkriminelle oder staatliche Akteure (Spionage) machen kann. Ein Datenleck kann schwerwiegende Folgen haben, von finanziellen Verlusten bis hin zu Reputationsschäden für die ETH. Unabhängig von Datenlecks ist zu beachten, dass viele KI-Anbieter weitreichende Nutzungsrechte an den eingegebenen Inhalten erhalten – die Kontrolle über diese Daten kann dadurch verloren gehen.

Manipulierte oder voreingenommene KI-Modelle

KI-Modelle können anfällig für Manipulationen und voreingenommen sein. Dies kann zu fehlerhaften oder diskriminierenden Ergebnissen führen (z.B. gegenüber einer bestimmten Altersgruppe). Die ETH legt grossen Wert auf die Integrität von Informationen, wie in der Weisung Informationssicherheit betont wird. Regelmässiges Überprüfen sowie stetiges, kritisches Hinterfragen der generierten Outputs durch die Nutzenden ist notwendig.

Urheberrechtliche Bedenken bei KI-generierten Inhalten

Die Fähigkeit Inhalte zu generieren, wirft urheberrechtliche Fragen auf in Bezug auf die Herkunft der Datensätze mit denen die KI trainiert wurde. Nutzende sollten sich deshalb bewusst sein, dass Inhalte, die sie mit KI kreieren, in ihrer akademischen Verantwortung liegen und dass diese Inhalte möglicherweise dem Urheberrecht unterliegen. Die ETH hat diesbezüglich Leitlinien für Nutzende entwickelt (vgl. Praktische Dos and Dont's weiter oben).

Training von KI mittels persönlicher Daten (AI Learning)

Viele KI-Systeme werden durch Nutzereingaben weiterentwickelt. Nutzende sollten sich deshalb bewusst sein, dass ihre Eingaben unter Umständen zur Verbesserung der KI-Modelle verwendet werden können. Falls möglich, sollte die Option zur Verwendung der Eingaben zu Test- oder Trainingszwecken in den Einstellungen des jeweiligen KI-Systems deaktiviert werden.

Weitere Informationen finden Sie hier: <https://ethz.sharepoint.com/sites/ArtificialIntelligence>

Gesetzgebung

In diesem Teil ist die relevante Gesetzgebung mit Bezug zur KI summarisch aufgeführt. Die Aufzählung erhebt keinen Anspruch auf Vollständigkeit. Es liegt in der Verantwortung der Nutzenden von KI, die für sie anwendbare Gesetzgebung festzustellen. Die einschlägigen Stellen an der ETH Zürich unterstützen bei Fragen.

AI Act der Europäischen Union (EU AI Act)

Obwohl die Schweiz nicht Teil der EU ist, ist es wichtig, den EU AI Act⁹ zu berücksichtigen, da er weitreichende Auswirkungen auf den Einsatz und die Entwicklung von KI-Systemen in Europa hat. Insbesondere wenn die genutzten KI-Systeme entweder Auswirkungen auf EU-Bürger haben, Daten in der EU verarbeiten oder wenn die generierten Outputs in der EU verwendet werden könnten. Der EU AI Act in aller Kürze:

- Risikobasierter Ansatz: Der EU AI Act kategorisiert KI-Systeme basierend auf ihrem Risikostadium (unakzeptabel, hoch, begrenzt, minimal);
- Verbotene Praktiken: Bestimmte KI-Anwendungen, die als besonders schädlich gelten, werden verboten;
- Anforderungen an Hochrisiko-KI-Systeme: Strenge Anforderungen an Datenverwaltung, Dokumentation, Transparenz, menschliche Aufsicht, Robustheit und Genauigkeit;
- Transparenzpflichten: Nutzer müssen informiert werden, wenn sie mit KI-Systemen interagieren.

Einhaltung des Bundesgesetzes über den Datenschutz (DSG)

KI-Systeme an der ETH müssen in Übereinstimmung mit dem DSG¹⁰ entwickelt und betrieben werden. Dies umfasst Prinzipien wie Transparenz, Zweckbindung, Datensparsamkeit und das Recht auf Auskunft und Löschung.

Die Weisung «Inventarisierung und Klassifizierung von Informationen an der ETH Zürich¹¹» bietet eine Hilfestellung im Umgang mit klassifizierten Informationen im Anhang 2, z.B. im Abschnitt E.

Einhaltung der Güterkontroll-Verordnung¹² (GKV)

Die Exportkontrolle ist ein Rechtsinstrument und bezweckt, dass Güter (nebst Produkten und Software auch Technologien, Fachwissen, Informationen, Forschungsergebnisse, Daten etc.) kontrolliert aus der Schweiz ausgeführt respektive exportiert werden, sofern diese Güter Eigenschaften besitzen, die nicht nur einen zivilen Einsatzzweck ermöglichen, sondern auch für den militärischen Bereich interessant sind (Dual-Use).

⁹ EU AI-Act, <https://artificialintelligenceact.eu>

¹⁰ DSG, <https://www.fedlex.admin.ch/eli/cc/2022/491>

¹¹ RSETHZ 203.28, <https://rechtssammlung.sp.ethz.ch/Dokumente/203.28.pdf>

¹² GKV, https://www.seco.admin.ch/seco/de/home/Aussenwirtschaftspolitik_Wirtschaftliche_Zusammenarbeit/Wirtschaftsbeziehungen/exportkontrollen-und-sanktionen/exportkontrolle_industriegueter/rechtliche-grundlagen-gueterlisten-anhaenge.html

Im Sinne der Exportkontrolle wird das Hochladen export-kontrollierter Daten in eine KI im Ausland oder in der Schweiz mit Zugriffsmöglichkeit aus dem Ausland als Export von Technologie betrachtet und Bedarf einer Bewilligung vom entsprechenden Bundesamt (Staatssekretariat für Wirtschaft, SECO).¹³

Ihr Kontakt an der ETH Zürich: [Abteilung Procurement und Export Services](#)

Ausblick: Emerging Threats und künftige Herausforderungen

Die ETH wird die Entwicklung von KI stetig beobachten und entsprechende Informationen zur sicheren Nutzung gegenüber neuen Bedrohungen und Herausforderungen anpassen.

Schlusswort

Die bestimmungsgemässe und verantwortungsvolle Nutzung von KI-Technologien erfordert kontinuierliche Aufmerksamkeit und stetige Anpassung an sich weiterentwickelnden Gegebenheiten. Als ETH-Mitarbeitende setzen wir uns gemeinsam dafür ein, die Chancen der KI zu nutzen und gleichzeitig Risiken zu minimieren – stets im Einklang mit unseren institutionellen Richtlinien und ethischen Grundsätzen.

Bei Fragen zum Thema Informationssicherheit wenden Sie sich an eine/n Information Security Officer (ISO), der für Ihr Department oder Ihre Abteilung verantwortlich ist, oder an den CISO. Eine Liste der Ansprechpartner findet sich hier: <https://ethz.ch/staffnet/de/service/informationssicherheit/ansprechpartner-informationssicherheit.html>

¹³ [Exportkontrollen und Sanktionen](#)